

ai-audit-report

AI Audit Report — Member 4

Declaration

I use AI tools for the following tasks: requirement extraction, coverage planning, test-case drafting, audit assistance, Postman/CI scaffolding and document structuring. Human review owns final validity, execution and defect decisions.

Interaction log

1. **AI-001 — Codex — 2026-08-31, local session.** Inspected Vietnamese requirements and member allocation. Evidence: req/2026.HW06.API_Testing_Vi.md, docs/hw06-phan-cong-cong-viec-nhom.md. Decision: accepted source extraction; noted FR-19 endpoint limitation.
2. **AI-002 — Codex — 2026-08-31, local session.** Inspected pinned SUT API specification and implementation. Evidence: GitHub SUT commit 85af3ba... Decision: risk input only; runtime proof required.
3. **AI-003 — Codex — 2026-08-31, local session.** Drafted FR-04/FR-10/FR-19 cases and traceability. Evidence: ../test-cases/member-4.csv. Decision: human audit required for every row.
4. **AI-004 — Codex — 2026-08-31, local session.** Drafted Postman/Newman/CI/report scaffolding. Evidence: ../postman/, root .github/. Decision: replace placeholders and capture authentic evidence.
5. **AI-005 — Codex — 2026-09-01, local session.** Reconciled Newman output, classified 66 failures and prepared submission artifacts. Evidence: ../newman/member-4/newman-full-report.json, failure-classification.md. Decision: classify fixture failures separately from reproducible defects.

Current draft audit count: 125 AI rows; 109 VALID and 16 INCOMPLETE. No AI row is silently discarded. The 15 HUMAN-001 rows are separate additions. INCOMPLETE rows use slash-separated status alternatives and carry a required correction: split the case or resolve one normative oracle before final execution.

Prompt transcript to preserve

Retain corresponding output rows in ../test-cases/member-4.json.

- P1. Extract FR-04, FR-10 and FR-19 endpoint contracts from api_specification.md and normative SRS. List actors, inputs, outputs, roles, state graph and relevant SEC rules. Flag unspecified schema/status assumptions.
- P2. For FR-04, generate at least 40 distinct API cases. Partition phone/name/address inputs, cover auth, identity binding, mass assignment, sensitive fields, XSS-safe output and response schema. Include precondition, data, expected status/body, cleanup and traceability.
- P3. For FR-10, generate a complete 5x5 state transition matrix plus cancellation, ownership, role, replay, malformed status, terminal-state and schema cases. Do not invent endpoints.
- P4. For FR-19, generate at least 40 cases for list/delete only. Cover admin authorization, IDOR, self-delete, invalid IDs, SQL-injection payloads, privacy and schema. Mark any role-update idea as out of contract.
- P5. Audit every row as VALID/INVALID/INCOMPLETE. Identify omissions, deduplicate, then add five human cases per feature that are genuinely absent from the generated set.

Recorded AI outputs (abridged, linked to retained rows)

- **P1 output:** normalized FR-04 profile, FR-10 order-state, and FR-19 admin-user contracts; flagged unspecified status/schema assumptions. Human decision: use invariant checks where the SRS is silent.
- **P2 output:** 40 FR-04 cases covering authentication, phone/name/address partitions, sensitive fields, XSS, IDOR and mass assignment. Human decision: retain 40 rows and mark ambiguous oracles INCOMPLETE.
- **P3 output:** 45 FR-10 cases, including the 5×5 transition matrix, cancellation rules, replay, terminal-state and role checks. Human decision: retain state graph and reject invented endpoints.
- **P4 output:** 40 FR-19 list/delete cases covering admin authorization, IDOR, self-delete, invalid IDs, SQL injection and privacy schema. Human decision: keep role-update ideas out of scope.
- **P5 output:** audit result 109 VALID, 16 INCOMPLETE, plus 15 human-added cases. Human decision: execute the corrected catalogue and classify failures using runtime evidence.

The complete row-level output is retained in ../test-cases/member-4.json and the generated CSV/XLSX exports.